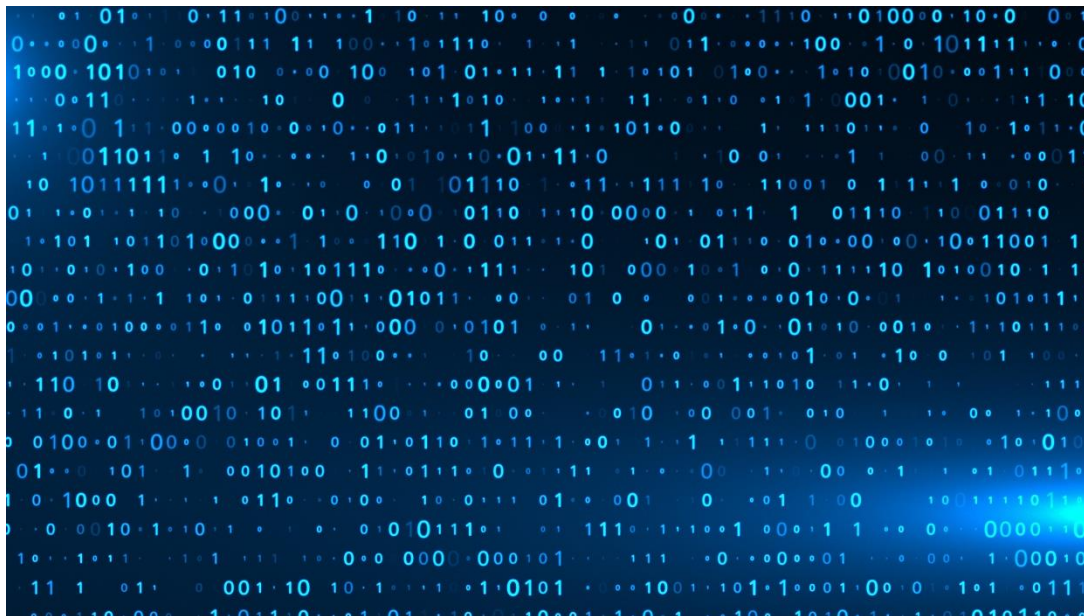


Curs 10-11

Securitatea retelelor

A series of horizontal lines of varying lengths and colors (teal, light blue, and white) extending from the left edge of the slide towards the right, positioned below the text 'Securitatea retelelor'.

Cadrul de securitate



CIA

- Principiul CIA = Confidentiality Integrity Availability
- **Confidențialitate**
 - utilizare neautorizata a informației
 - divulgare neautorizata a informației
- **Integritate**
 - Informatie complete si exacte
 - Integritatea sistemului vs integritatea datelor
- **Disponibilitate**
 - Access la informații in momentul in care este necesar

Provocari de securitate

- Securitatea la nivel de sistem
 - Protecția informațiilor din sistemul de calcul / sistemul de operare
 - Aplicații informatice pentru protecția datelor și informațiilor
- Securitatea la nivel de rețea
 - Protecția datelor în rețea
- Securitatea la nivel internet
 - Protecția datelor pe internet

Controlul accesului

Tipuri de vulnerabilitati

Controlul accesului

- permisiunea de utilizare a unui obiect de către un utilizator.
- 3 servicii
 - Autentificare
 - Utilizatorii cu drept de access
 - Se poate extinde la procese sau dispozitive
 - Autorizare
 - Actiunile care pot fi facute utilizatori in urma autentificarii
 - Responsabilitate
 - ce actiuni a făcut un utilizator

Controlul accesului

Studiu de caz
Extras din RFC 3552

“

- *Authorization vs. Authentication*
- *Authorization is the process by which one determines whether an authenticated party has permission to access a particular resource or service.*
- *Authentication simply identifies a party, authorization defines whether they can perform a certain action.*
- *Authorization necessarily relies on authentication, but authentication alone does not imply authorization.*
- *Rather, before granting permission to perform an action, the authorization mechanism must be consulted to determine whether that action is permitted. “*

Controlul accesului - Autentificare

Autentificarea presupune identificarea utilizatorului:

- Identitatea
 - Se stabileste prin numele de utilizator
- Verificarea identitatii
 - Prin informatii cunoscute (parola, PIN, etc)
 - Prin obiecte in posesie (token, card, RFID etc)
 - Prin biometrie (amprenta, recunoastere faciala, iris, voce etc)

Controlul accesului - Autentificare

Two-factor Authentication

- utilizatorul furnizează cel puțin 2 modalități de autentificare:
 - Informație cunoscută: Nume de utilizator/ID de utilizator și parolă
 - Obiecte în posesie: Token folosind o parolă unică (one-time password OTP)
- OTP-ul este generat folosind un dispozitiv electronic sau o aplicație instalată pe un dispozitiv în posesia utilizatorului
 - OTP diferit generat de fiecare dată
 - OTP expiră după un timp definit

Controlul accesului - Autorizarea

Autorizarea

- Definește drepturile și permisiunile utilizatorului pe a utiliza informații / resurse dintr-un sistem
- Acordă unui utilizator:
 - acces la o anumită resursă
 - dreptul de a desfășura acțiuni asupra acelei resurse
- Accesul este acordat în funcție de nivelul de încredere și poate fi asociat cu:
 - Rol
 - Grup
 - Locație
 - Oră
 - Tip tranzacție

Controlul accesului - Autorizarea

Single Sign On

- Single Sign-On (SSO) este un mecanism de autentificare care permite utilizatorilor să acceseze mai multe aplicații sau servicii utilizând o singură autentificare.
- După logarea inițială, utilizatorul nu mai este obligat să introducă credențialele pentru fiecare resursă pe care o accesează.
- un utilizator se conectează o singură dată și obține acces la toate resursele din sistem la care are dreptul

Controlul accesului - Autorizarea

Single Sign On

- SSO utilizează un furnizor de identitate (Identity Provider - IdP) pentru
 - a autentifica utilizatorii
 - a furniza aplicațiilor servicii de autentificare.

Componentele SSO

1. Identity Provider (IdP):

- Sistemul care gestionează autentificarea utilizatorului (ex.: Azure AD, Okta, Google Identity).

2. Service Provider (SP):

- Aplicația sau serviciul care solicită autentificarea (ex.: aplicații SaaS, platforme web).

3. Protocoluri de autentificare:

- Standarde precum SAML, OAuth 2.0 și OpenID Connect sunt folosite pentru a gestiona autentificarea.

Controlul accesului - Autorizarea

Protocoale Single Sign On - 1

- SAML (Security Assertion Markup Language)
 - Protocol bazat pe XML.
 - Permite transmiterea informațiilor despre autentificare între IdP și SP.
 - Utilizat de multe aplicații enterprise.
- OAuth 2.0
 - Protocol de autorizare folosit pentru accesul securizat la resurse.

Controlul accesului - Autorizarea

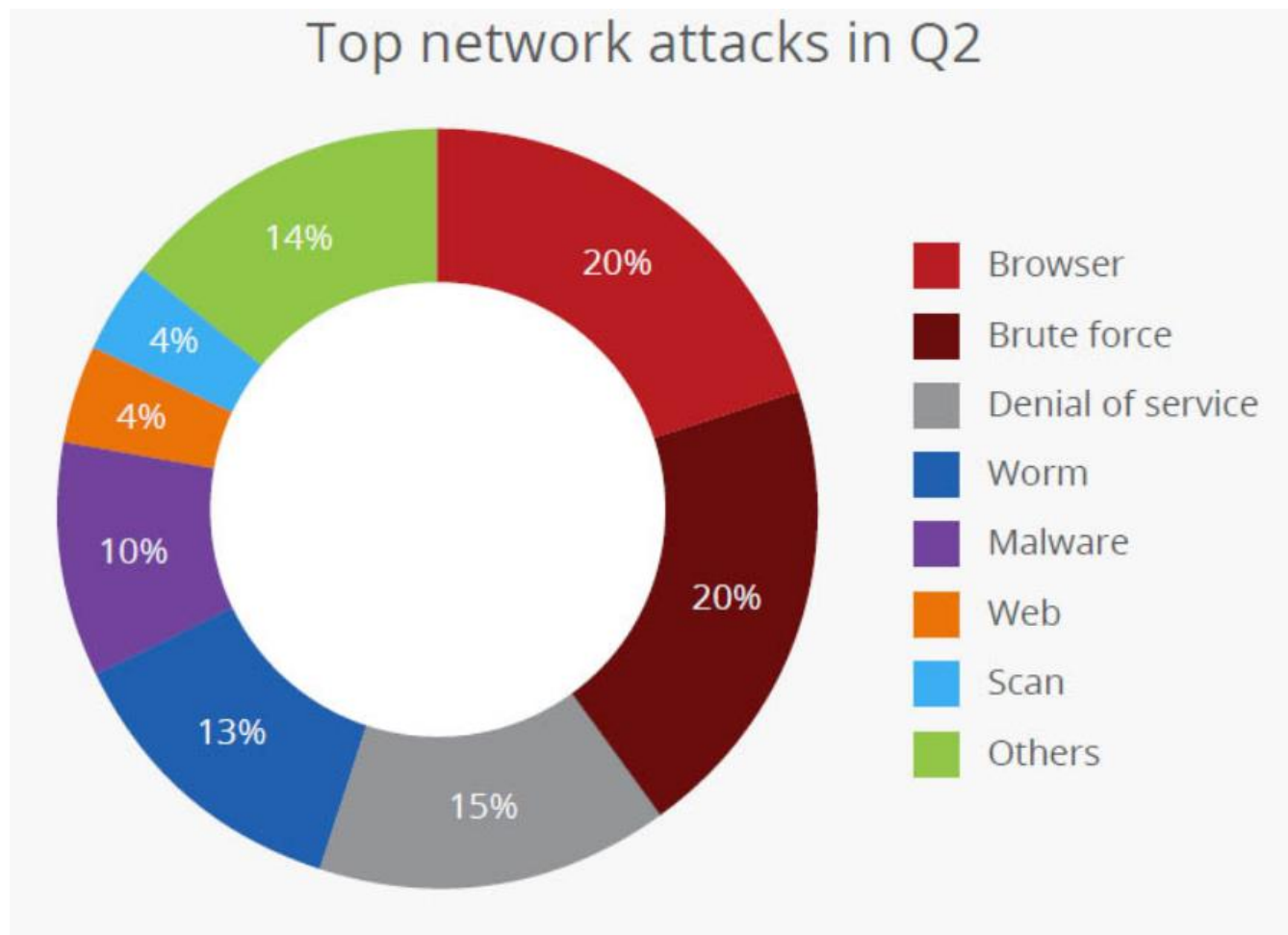
Protocoloale Single Sign On - 2

- OpenID Connect (OIDC)
 - Extensie a OAuth 2.0.
 - autentificare și schimb de informații despre utilizator.
- Kerberos:
 - este un protocol care permite autentificarea reciprocă, prin care atât utilizatorul, cât și serverul verifică identitatea celuilalt pe conexiuni de rețea nesigure.
 - folosește un serviciu de acordare a tichetelor care emite token-uri pentru a autentifica utilizatorii și aplicațiile

Securitatea rețelelor

Tipuri de vulnerabilitati

Atacuri de retea



Source: McAfee Labs, 2017.

Tipuri de atacuri

Alte atacuri:

- **Atacuri fizice**
 - Acces in locatie si acces la echipamente
- **Insider Attacks**
 - Atacuri ce utilizeaza o “persoana din interior” care faciliteaza
- **Advanced Persistent Threats**
 - Atacuri ale grupurilor organizate de “hackeri”
 - Atacuri personalizate in functie de sistem
 - Obiective clare: furt de informatii, rascumparari, razbunare, popularitate ...

Tehnici utilizate pentru atacuri

- **Redirection**

- Schimbarea destinatarului

- **Programe malitioase**

- Worms, Viruses, Trojans

- **Masquerading**

- Camuflarea unei adrese

- **Social Engineering**

- “Inselatorii”

- **Sniffing**

- captura parolei

- **Brute Force:**

- Identificarea parolei

- **Buffer Overflows**

- Se depaseste dimensiunea alocata

- **Spoofing Attacks:**

- Camuflarea adreselor

- **Flooding**

- “inundarea” cu mesaje

Categorii de atacuri - clasificare

- **DOS Attacks**
 - Denial of Service
- **Disclosure Attacks**
 - Publicarea de informatii
- **Modification Attacks**
 - Modificarea informatiilor
- **Destructive Attacks**
 - Atacuri directionate catre distrugerea datelor (...)
- **Escalation of Privilege**
 - Alocarea ilegala a unor drepturi de acces

Categorii de atacuri - clasificare 2

- Sniffing
 - captura parolei
- Brute Force:
 - Identificarea parolei
- Buffer Overflows
 - Se depaseste dimensiunea alocata
- Spoofing Attacks:
 - Camuflarea adreselor
- Flooding
 - “inundarea” cu mesaje
- Redirection
 - Schimbarea destinatarului
- Programe malitioase
 - Worms, Viruses, Trojans
- Masquerading
 - Camuflarea unei adrese
- Social Engineering
 - “Inselatorii”

Categorii de atacuri -

Exemplu: Masquerade

- Masquerade Attacks (exemple):
 - Se mascheaza adresa “Address Spoofing ”
 - MAC Address Spoofing
 - IP/MAC Address Spoofing
 - DNS Attacks
 - Web Proxy Auto-Discovery Protocol (WPAD) Hi-Jacking
 - Website Spoofing -- Portal Spoofing

Tehnici de securitate – Detectia intrusilor

Elemente de baza in detectia intrusilor:

- Viteza de detectie
- Eficienta de detectie -> descurajare
- Colectarea de informatii despre tehnicile folosite

Metode generale:

- Detectia comportamentului anormal
 - Detectia bazata pe elemente de prag
 - Detectia bazata pe profil
- Detectia bazata pe semnatura

Metode de inregistrare a activitatii:

- Inregistrari native: SO pastreaza activitatea utilizatorilor
- Inregistrari specifice: Aplicatii ce retin doar informatiile necesare detectiei

Securitatea la nivel de aplicatie

Denial of Service

Tipuri de atacuri

Social Engineering

- arta manipulării persoanelor, astfel încât acestea să renunțe la informații confidențiale.
- se bazează pe: **incredere, neatenție sau curiozitate**
- Cel mai des întâlnit:
 - mesaje e-mail: contin un link, contin un fisier, solicita informanții
 - social media: site-uri, rețele de socializare
 - telefon
 - messenger

Tipuri de atacuri

Social Engineering

- Tipuri comune de atacuri:
 - **“Email from a friend”**
 - Ex: Cere ajutor o suma de bani / cere donatii in numele unei asociatii
 - **“Phishing”**
 - Trimiterea unui mail utilizand ilegal numele unei organizatii ...
 - Se bazeaza pe incredere
 - Ex: Anunta o problema (parola, spatiu), anunta un castig ...
 - **“Baiting”**
 - se utilizeaza un scenariu
 - Ex: un link catre un film nou care odata accesat deschide noi pagini si incearca fortarea descarcarii unor fisiere

Atacuri la nivel de aplicatie

- Social engineering
 - manipulare (psihologică) a comportamentului uman pentru a afla detalii de securitate
 - Doua categorii:
 - computer- or technology-based deception
 - human-based deception.
- Data breach
 - Sustragere de date dintr-un sistem fara acordul proprietarului
- Espionage / Man in the middle
 - Obținerea de informatii confidentiale

Exmplu:

Social engineering

 3 messag

 From: **Freddy Hodges**
To: **mi** 3:59 PM

 build assemblies_555568.zip (7.9 KB) [Download](#) | [Briefcase](#) | [Remove](#)

hi mi!

I have attached a revised spreadsheet contains invoices. Please check if it's correct

Regards,
Freddy Hodges

[Read more](#) [view](#)

Avertizare

1 mess

 From: **Webmaster**

3/12/20

Contul dvs. au ajuns la limita dat de către administrator. Faceți clic pe linkul de mai jos acum pentru a actualiza contul tău.

<http://jkdsdsjkdsn.tripod.com/>

mulțumiri

Tipuri de atacuri

“Browser Attacks”

- Ataca un calculator prin intermediul unui browser web.
 - Utilizeaza **site-uri vulnerabile** (legitime sau nu)
 - atacatorii infectează site-ul cu programe malware.
 - site-ul infectat încearcă să **forțeze descarcarea de malware**-ul pe sistemele tinta exploatand vulnerabilitățile existente

“Brute Force Attacks”

- programe de calculator utilizate pentru a încerca un număr foarte mare de parole pentru a decifra mesajul sau pentru a avea acces la sistem

Tipuri de atacuri

“Session Hijacking”

- conectarea permanenta la internet presupune **tranzacții repetate** cu servere din întreaga lume,
 - o sesiune dintre computer și serverul web contine un ID de sesiune unic, care trebuie să rămână privat
 - un atacator poate **capturare ID-ului de sesiune**, permițându-i să se conecteze în calitate de utilizator și să obțină acces la informații neautorizate pe serverul web.

“Credential Reuse”

- **Prea multe credentiale (login și parola)**
 - Tentatia de a reutiliza credentiale pentru a ușura viața.
 - Solutie:
 - parole unice pentru toate aplicațiile și site-urile web
 - Aplicații manager de parole – atenție la posibile probleme

Tipuri de atacuri

“**Malware Attacks**” - “malicious software”

- “Phishing emails”
 - Descarcarea de **atasamente** ale e-mail-urilor “capcana”
- “Malicious websites”
 - site-uri care includ kituri de exploatare concepute pentru a găsi **vulnerabilități în sistemul vizitatorilor** site-ului
 - site-urile configurate pentru a deghiza malware-ul ca fișier legitim ce trebuie descărcat.
- “Malvertising”
 - rețelele de publicitate
 - anunțurile rău intenționate pot **redirecționa utilizatorii** către un site web care găzduiește programe malware

Tipuri de atacuri

“Worm Attacks”

- Programele **Malware** necesită, de obicei, intervenția utilizatorilor pentru a începe infecția.
 - O persoană descarcă un atașament de e-mail, vizitează un site infectat sau conectează un drive infectat
- “viermii” se răspândesc **fără intervenția utilizatorului**, printr-un mecanism de răspândire propriu.
 - nu necesită interacțiune cu utilizatorul.
 - exploatează vulnerabilitățile de sistem pentru a se răspândi în rețelele locale și dincolo de acestea.
 - Ex: “WannaCry” a exploatat o vulnerabilitate a SO: Windows pentru a se răspândi și infecta

Tipuri de atacuri

Web Attacks

- Cross-Site Scripting (XSS)
 - Se **injectează un cod** rău intenționat, într-o pagina web
 - Se execută un script, în browser, la încărcarea paginii.
- SQL Injection (SQLi)
 - Se bazează pe introducerea unui **cod SQL** în locul datelor standard într-un câmp de introducere de date
 - atacatorul introduce cod SQL pentru a șterge sau fura date
- Path Traversal
 - Accesarea unor zone restrictionate dintr-un site prin mesaje cerere HTTP
 - Se ocolesc metodele de restrictionare acces implementate

Exemple - SQL injection

SQL Injection Based ON 1=1 is Always True

Username or Email	johnsmith	Register
Password	mypassword	Lost Password?



```
SELECT * FROM `users`
WHERE `username` = 'johnsmith'
AND `password` = 'mypassword'
```

Username or Email	'OR 1 = 1; /*	Register
Password	*/ --	Lost Password?



```
SELECT * FROM `users`
WHERE `username` = '' OR 1 = 1; /*'
AND `password` = '*/--'
```

Exemple - SQL injection

Studiu de caz

- SQL Injection Based on Batched SQL Statements

Server Code

```
txtUserId = getRequestString("UserId");  
txtSQL = "SELECT * FROM Users WHERE UserId = " + txtUserId;
```

User input:

105; DROP TABLE Suppliers



Result:

SELECT * FROM Users WHERE UserId = 105; DROP TABLE Suppliers

Tipuri de atacuri

Scan Attacks

- “Port scanner”
 - Se scaneaza porturi (adresa nivel transport) pentru identificarea de vulnerabilitati la nivel aplicatie sau SO
- Vulnerability scanner
 - Se scaneaza sisteme din retea pentru identificarea de vulnerabilitati cunoscute ale aplicatiilor sau SO

Man-in-the-Middle Attacks

- Atacatorul insereaza un nod intermediar intre sursa si destinatie
 - Poate captura traficul si implicit datele transmise (parole)
 - Poate redirectiona catre servicii fictive

Denial of Service

- Afectează funcționarea unui serviciu prin supraincercarea server-ului sau a rețelei
- Consumă resurse ale sistemului și ale conexiunii la rețea a furnizorului de servicii
- Tipuri principale de DoS:
 - Simple DoS
 - Coordinated DoS
 - Distributed DoS

Denial of Service” (DOS)

“**blocarea unui serviciu** oferit

- împiedică utilizarea normală a unui portal, a unui sistem sau a rețelei de către utilizatori
- încearcă să oblige o resursă (ex: site-uri web, servere de aplicatii sau servere DNS) sa proceseze un volum foarte mare de trafic.
- obiectivul este să încetinească sau să se blocheze sistemul.
- Cel mai des intalnit atac DDoS presupune **Flood** – inundatie cu:
 - Mesaje uzuale
 - Cereri de deschidere de conexiuni
 - Mesaje cu structura compromisa

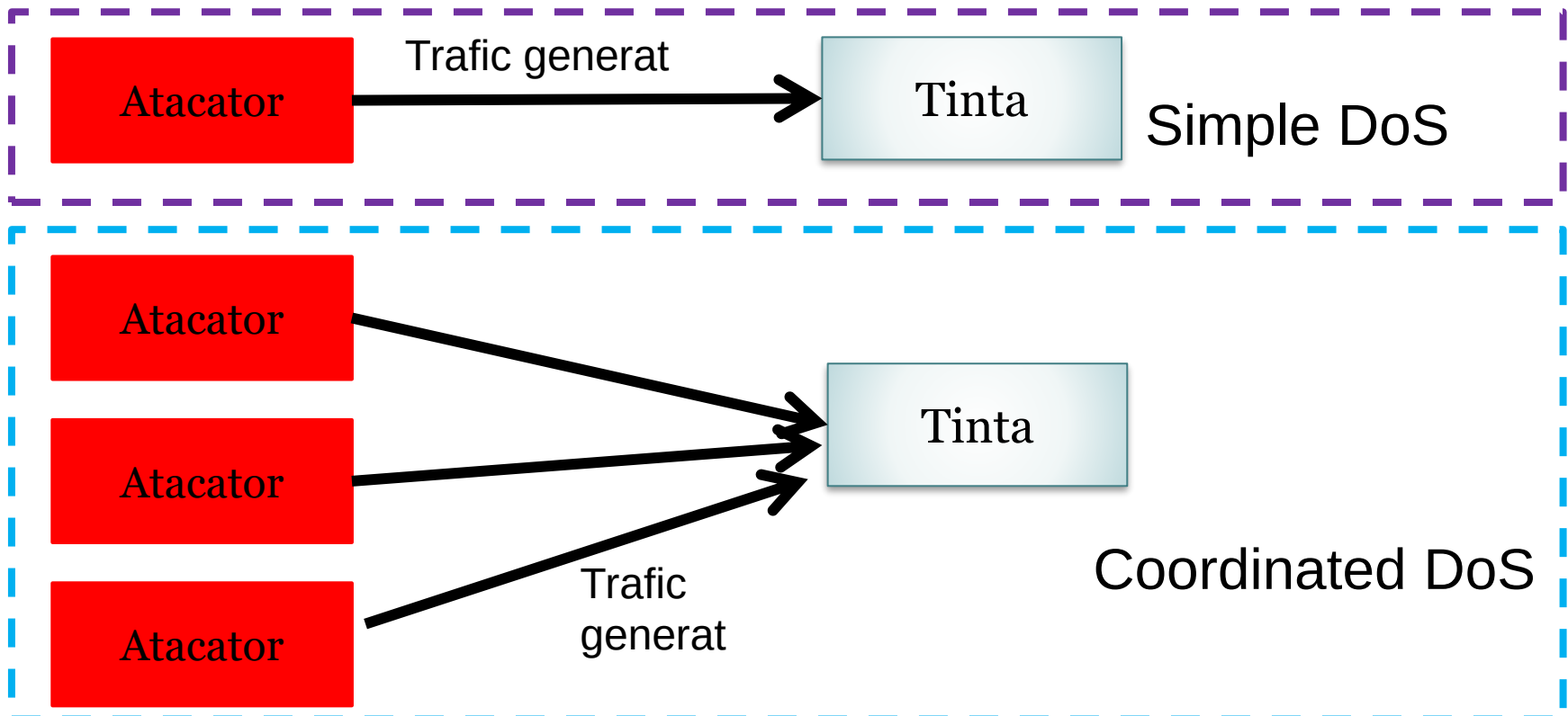
Categorii de atacuri - DOS

- DOS -- Denial of Service Attacks (exemple):
 - Radio Signal Interference
 - AP Interference, example: steal MAC, steal IP
 - Channel Hogging
 - Disassociation Attacks
 - Flooding Packets
 - ARP Poisoning
 - TCP reset attacks
 - Window Size Changes
 - UDP Flooding
 - ICMP Flooding
 - BROADCAST Flooding

Exmplu:

Denial of Service

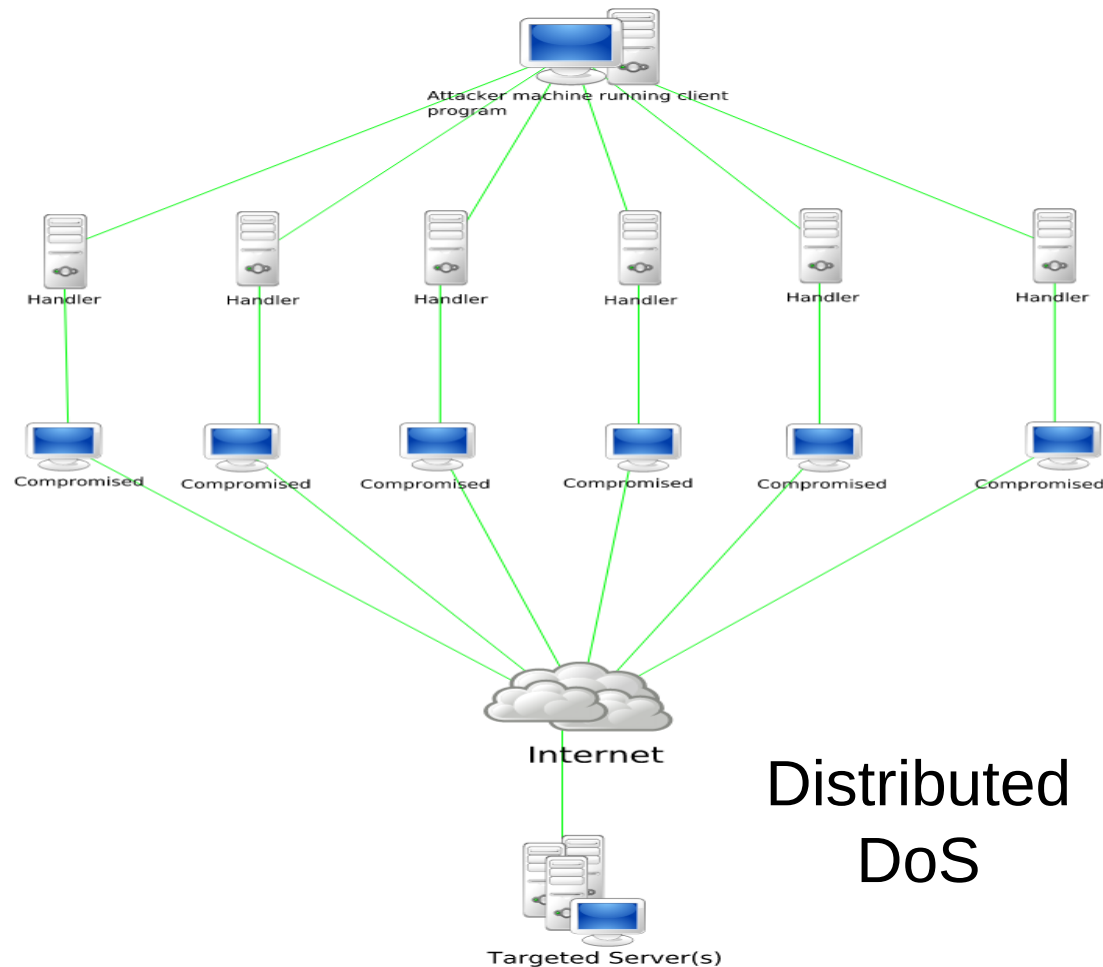
- Atacatorul ascunde IP-ul sursa pentru a masca originea atacului



Exmplu: Denial of Service

- **Handler**
 - server cu volum mare de trafic pentru a ascunde urma
- **Agent**
 - host dintr-o retea
- **Noduri multiple**
 - intre atacator si tinta pentru a amplifica si ascunde

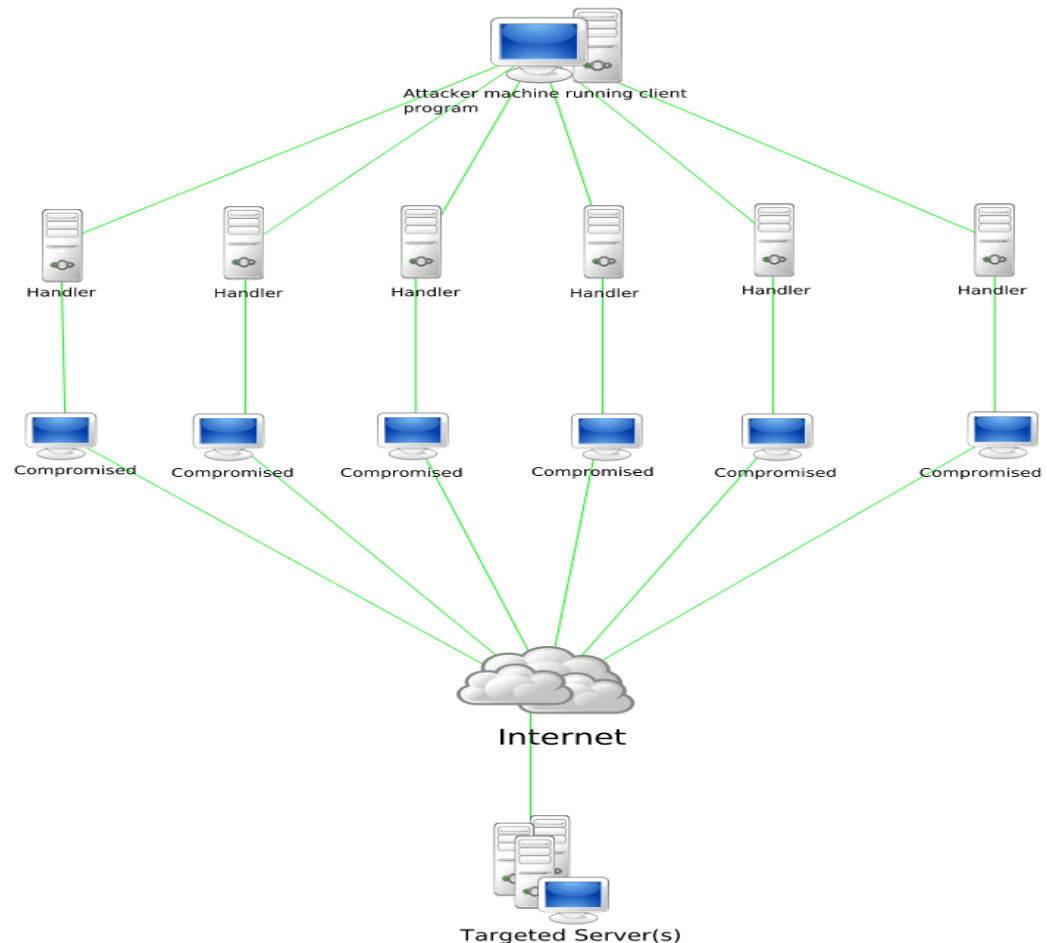
Pot fi oprite, de obicei, doar cu ajutorul furnizorului de internet



Denial of Service

- Handler = server cu volum mare de trafic pentru a ascunde urma
- Agent = host dintr-o retea
- Noduri multiple între atacator și tinta pentru a amplifica și ascunde

Distributed DoS



Denial of Service

- **DDoS amplification/reflection**

- Atacatorul cloneaza IP-ul victimei si trimite cereri catre server (exemplu: UDP). Serverul raspunde catre victima.
- Resultat: incarcarea conexiunii internet a victimei

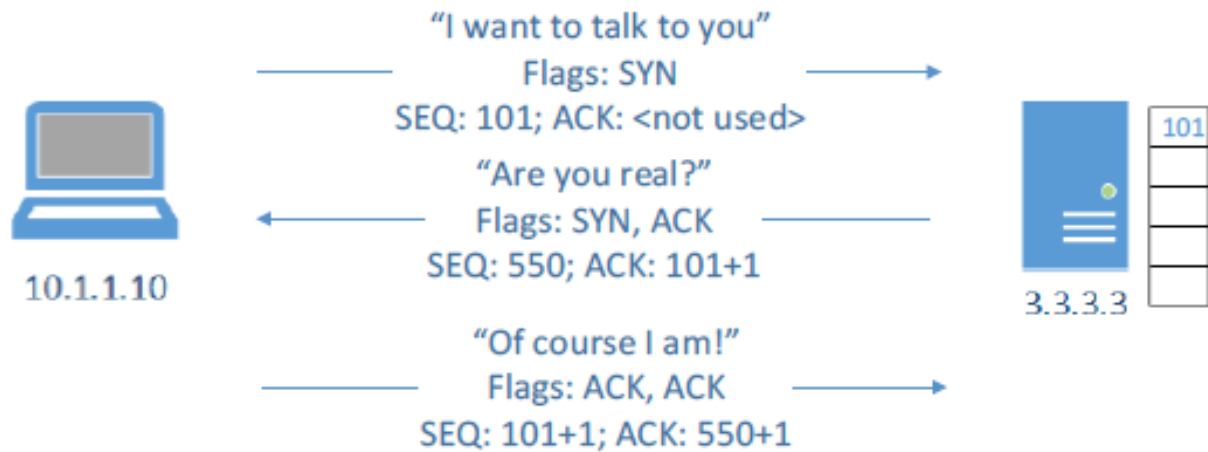
- **DoS protocol exploitation**

- succesiune de cereri către un sistem țintă într-o încercare de a consuma suficiente resurse
- Rezulta: sistemul nu răspunde / răspunde intarziat.
- Exemplu: TCP-SYN

Denial of Service

- **DoS flooding**
 - atacatorul incarca victima cu pachete
 - atacatorul are lățime de bandă mai mare decât victima
- **DoS malformed packet attack**
 - blocheaza stiva de rețea (sistemul de operare) prin furnizarea de informații gresite in antet sau in mesaj
- **DoS application attack**
 - limitări, defecte și vulnerabilități ale aplicație sunt exploatare,
 - Rezultat: blocarea aplicației sau corupere a datelor

Exemple - DDoS - SYN flood

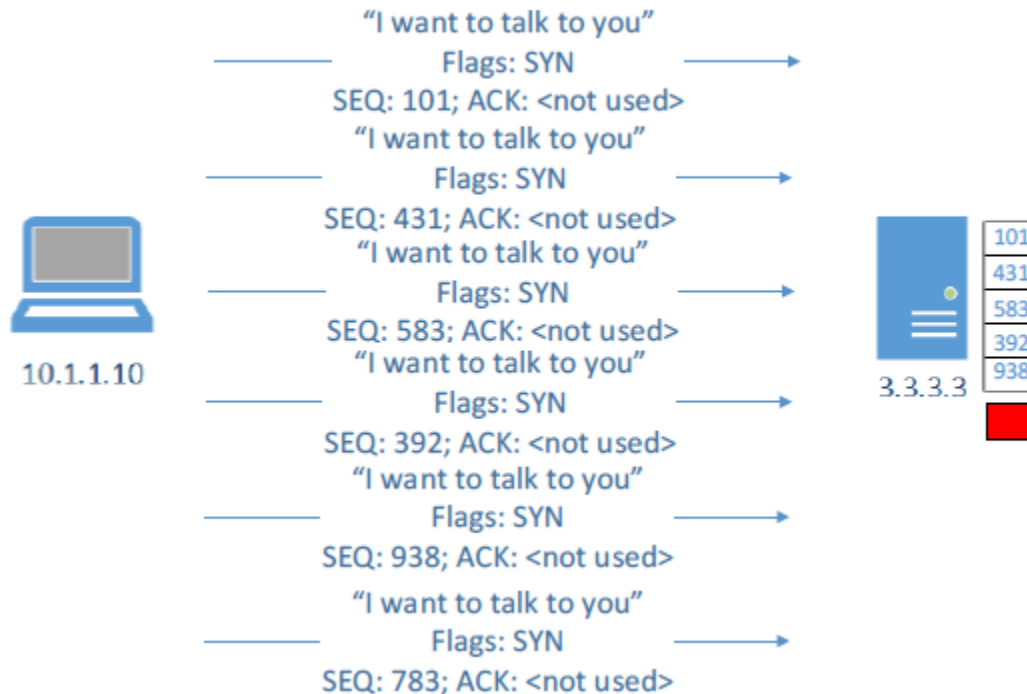


Normal

Studiu de caz

Exemple - DDoS - SYN flood

Atac



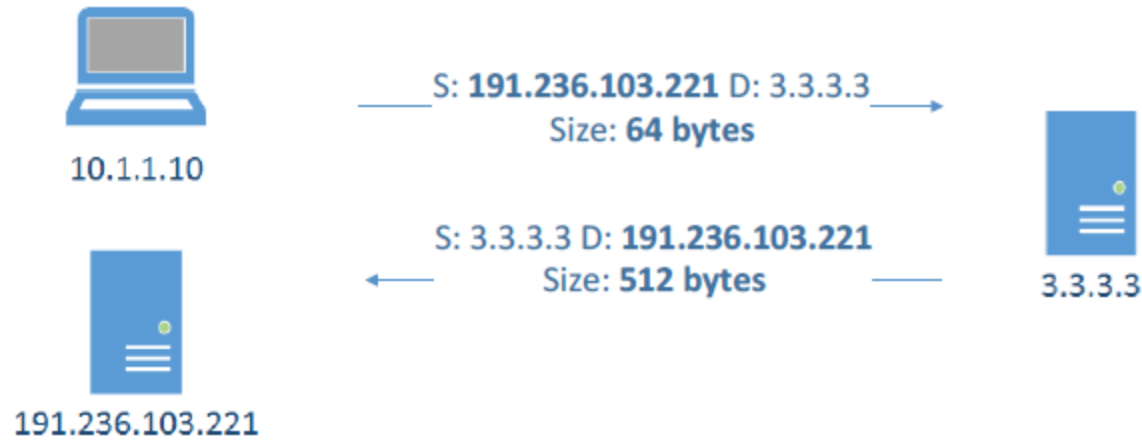
Exemple - DDoS -Socket exhaustion

- Socket exhaustion would look likethis:

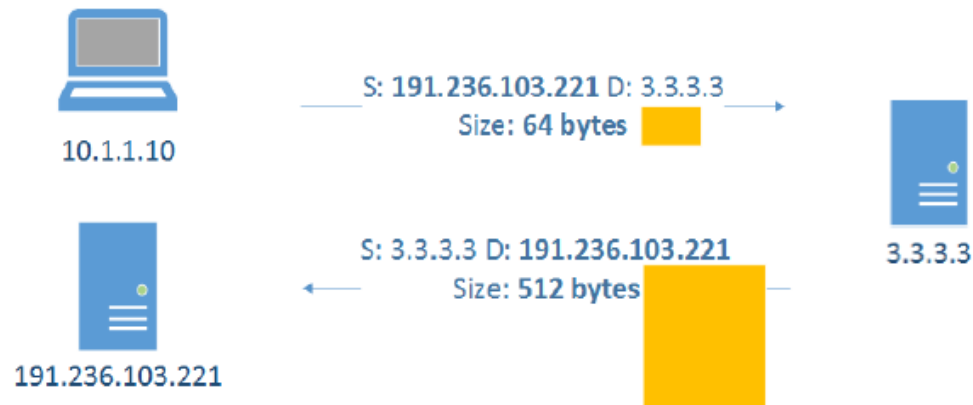
Active Internet connections (servers and established)

Proto	Recv-Q	Send-Q	Local Address	Foreign Address	State	PID/Program name
tcp	0	0	0.0.0.0:111	0.0.0.0:*	LISTEN	1339/rpcbind
tcp	0	0	0.0.0.0:33586	0.0.0.0:*	LISTEN	1395/rpc.statd
tcp	0	0	192.168.122.1:53	0.0.0.0:*	LISTEN	1962/dnsmasq
tcp	0	0	127.0.0.1:631	0.0.0.0:*	LISTEN	1586/cupsd
tcp	0	0	127.0.0.1:25	0.0.0.0:*	LISTEN	2703/sendmail: acce
tcp	0	0	0.0.0.0:1241	0.0.0.0:*	LISTEN	1851/nessusd: waiti
tcp	0	0	127.0.0.1:25	127.0.0.1:60365	TIME_WAIT	-
tcp	0	0	127.0.0.1:25	127.0.0.1:60240	TIME_WAIT	-
tcp	0	0	127.0.0.1:25	127.0.0.1:60861	TIME_WAIT	-
tcp	0	0	127.0.0.1:25	127.0.0.1:60483	TIME_WAIT	-
tcp	0	0	127.0.0.1:25	127.0.0.1:60265	TIME_WAIT	-
tcp	0	0	127.0.0.1:25	127.0.0.1:60618	TIME_WAIT	-
tcp	0	0	127.0.0.1:25	127.0.0.1:60407	TIME_WAIT	-
tcp	0	0	127.0.0.1:25	127.0.0.1:60423	TIME_WAIT	-
tcp	0	0	127.0.0.1:25	127.0.0.1:60211	TIME_WAIT	-
tcp	0	0	127.0.0.1:25	127.0.0.1:60467	TIME_WAIT	-
tcp	0	0	127.0.0.1:25	127.0.0.1:60213	TIME_WAIT	-

Exemple - DDoS -



Reflective attacks



amplification attack

Atacuri la nivel DNS

- DNS registrar hijacking
 - Compromiterea unui DNS registrar
 - Modificare a “domain registration information”
 - Rezultate: control asupra domeniului, transferul domeniului sau “identity theft”.
- DNS spoofing
 - spoof “DNS records”.
 - Modalitati: compromitere a server-ului DNS, DNS cache, man-in-the-middle attack ...

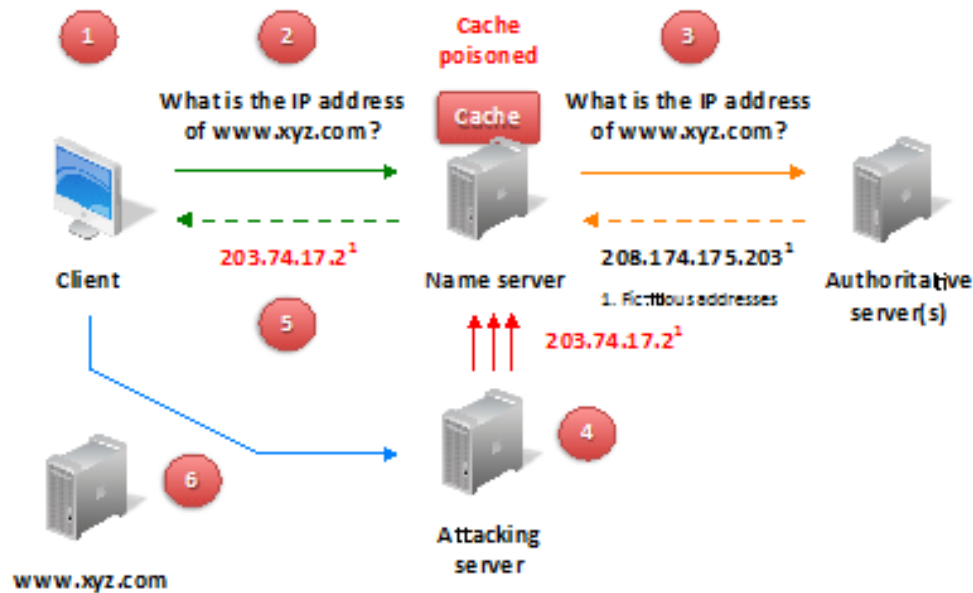
Atacuri la nivel DNS

- DNS poisoning
 - introducere de informatii compromise in DNS (cache)
 - Bazate pe: vulnerabilitati ale protocolului DNS sau ale aplicatiilor DNS
- Domain name collision
 - domeniu utilizat ca “private name space” (non-delegated Top Level Domain),
 - DNS query catre DNS si returnarea unui alt domeniu

Exemplu DNS

Studiu de caz

DNS Cache Poisoning



Securitatea la nivel IP si ICMP

Tipuri comune de atacuri

- Ascultarea – Captura de pachete
- Modificarea datelor
- Identity spoofing
- Atacuri bazate pe parole
- DoS – Denial of Service
- Man in the Middle
- Cheie Compromisa
- Sniffer

Atacuri router

- Autonomous System (AS) hijacking
 - Un atacator se da drept organizatia victima
 - Acesta anunta prefixul (retea) victimei – Autonomous Systems
- Address space hijacking (IP prefixes)
 - “rogue BGP peer” anunta prefixul victimei
 - Redirectioneaza o parte sau tot catre AS-ul compromis

Atacuri router

- Route leaks
 - AS 1 nu are conexiune cu AS-ul 2.
 - AS-ul 1 informeaza vecinii despre rutele BGP primite de la AS-ul 2. In acest caz traficul catre AS 2 va fi transmis prin AS1.
- BGP session hijacking
 - Compromiterea tabelului de routare BGP
 - Poate impiedica traficul catre AS-uri fara a notifica

Eavesdropping

- Eavesdropping Attacks (exemple):
 - Atacuri de tip “ascultare”
 - MAC Address
 - IP Address
 - BaseStation Address
 - cleartext passwords and keys
 - password hashes
 - wep keys
 - SSIDs

IP Spoofing

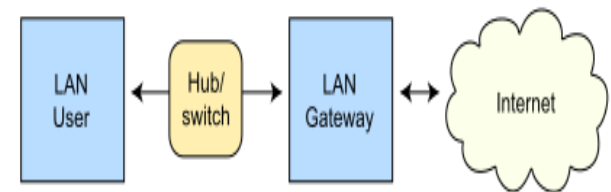
- Orice host poate trimite un pachet cu alt IP sursa decat cel alocat
- Mesajele “Reply” vor ajunge la IP-ul trecut ca sursa (valabil doar pentru IP din alt subnet)
- Atac: broadcast care are IP-ul victimei -> victima va primi raspuns de la intreaga retea
- Poate folosi orice protocol IP (ICMP, TCP, UDP)

Man in the middle

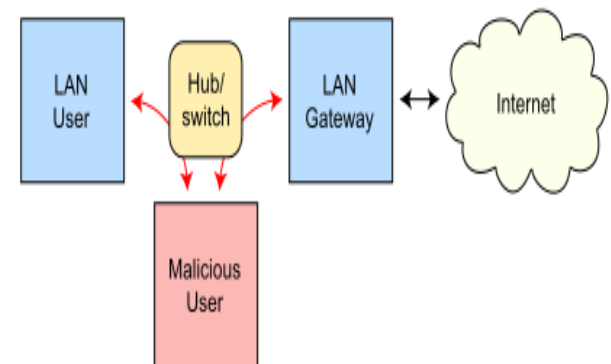
ARP Poisoning

- ARP Poisoning
 - Un atacator își asociază adresa MAC cu adresa IP a altui host
 - traficul destinat acelei adrese IP este trimis catre atacator.
- ARP Poisoning Tools
 - Ettercap ...
- Solutii de securitate:
 - Static ARP
 - `arp -s ip_server hw_address_server`
 - Surveillance tools: Arpwatch, Ettercap

Routing under normal operation



Routing subject to ARP cache poisoning



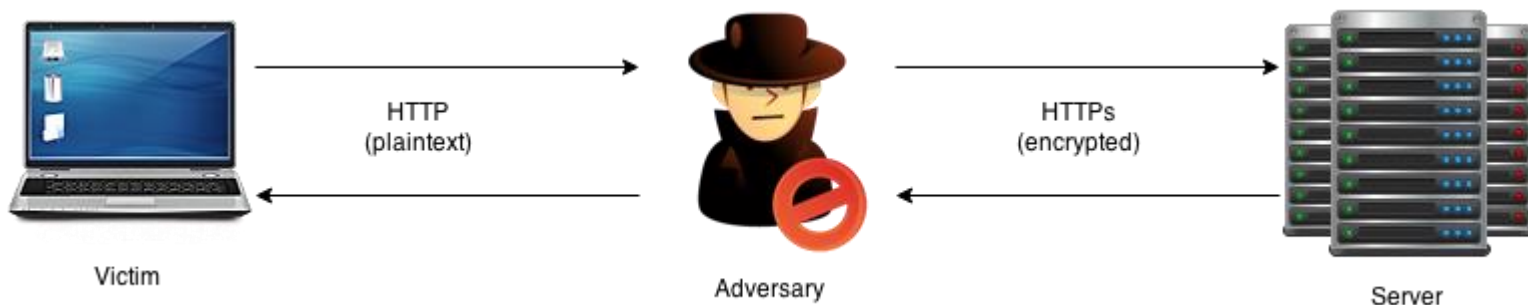
By 0x55534C (Own work) [CC BY-SA 3.0
(<http://creativecommons.org/licenses/by-sa/3.0>)], via
Wikimedia Commons

Man in the middle

Exemplu HTTS downgrade

- **SSLStrip**

- Scopul este de a ocoli conexiunile SSL care sunt transformate in conexiunile de tip cleartext - HTTP.
- când un utilizator acceseaza un site, browserul acceseaza versiunea HTTP. Dacă site-ul este disponibil HTTPS, atunci va solicita clientului să se reconecteze prin HTTPS
- SSLStrip este folosit într-un scenariu Man-in-Middle pentru a suprascrie această funcție. Clientul vede conexiunea cu serverul in plaintext (HTTP), in timp ce serverul considera clientul conectat prin HTTPS

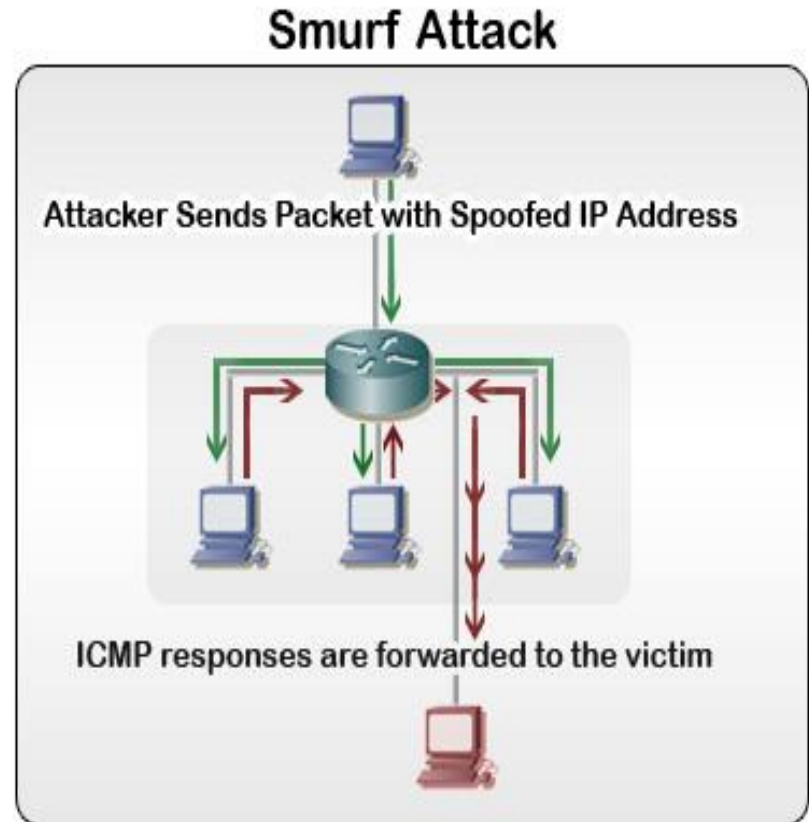


ICMP

- Internet Control Message Protocol
- Tratarea erorilor si debugging -> nu necesita autentificare
- Tipuri de mesaje:
 - 40 alocate
 - 255 posibile
 - Cele mai cunoscute: **0 - Echo Reply / 8 – Echo**
 - Implementare: comanda ping
 - Maparea unei retele prin “ping” catre toate IP-urile din retea

Smurf Attack

- Ping catre adresa “broadcast address”, cu (spoofed) IP al victimei
- Atac: Amplificare si IP spoofing
- Prevenire: “Dropp internet broadcast”

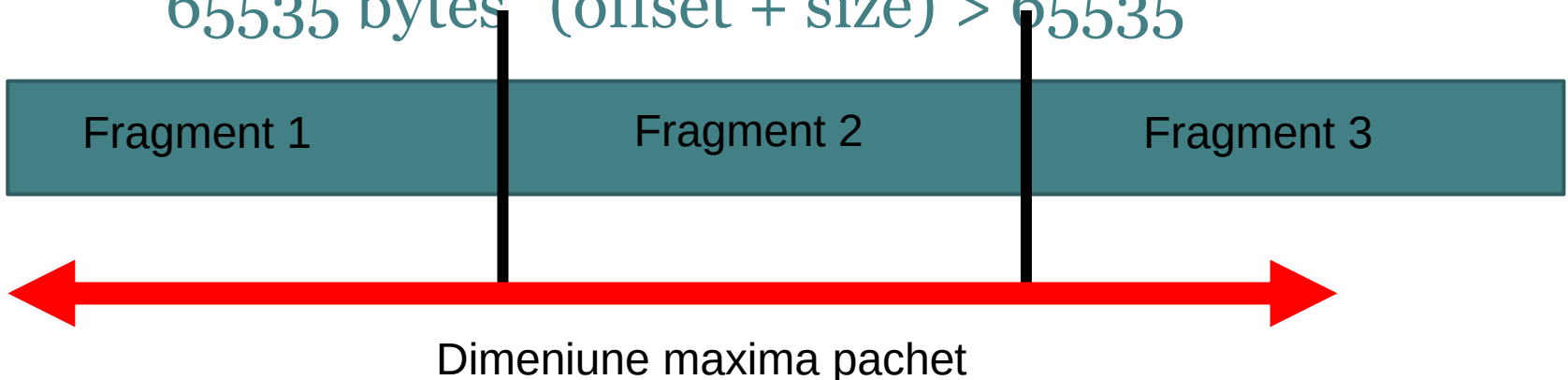


Fragmentarea

- Dimensiuni diferite de cadre “frame size” in functie de protocolul folosit (ex: Ethernet)
 - “MTU”= “Maximum Transmission Unit”
- Fragmentarea = impartirea in mai multe cadre “frame”
- Componente:
 - “Fragment ID” – acelasi ID pentru toate fragmentele
 - “bit flag” o daca este ultimul fragment / 1 default
 - “offset” – unde vor fi incluse datele
 - “Data length” - dimensiune

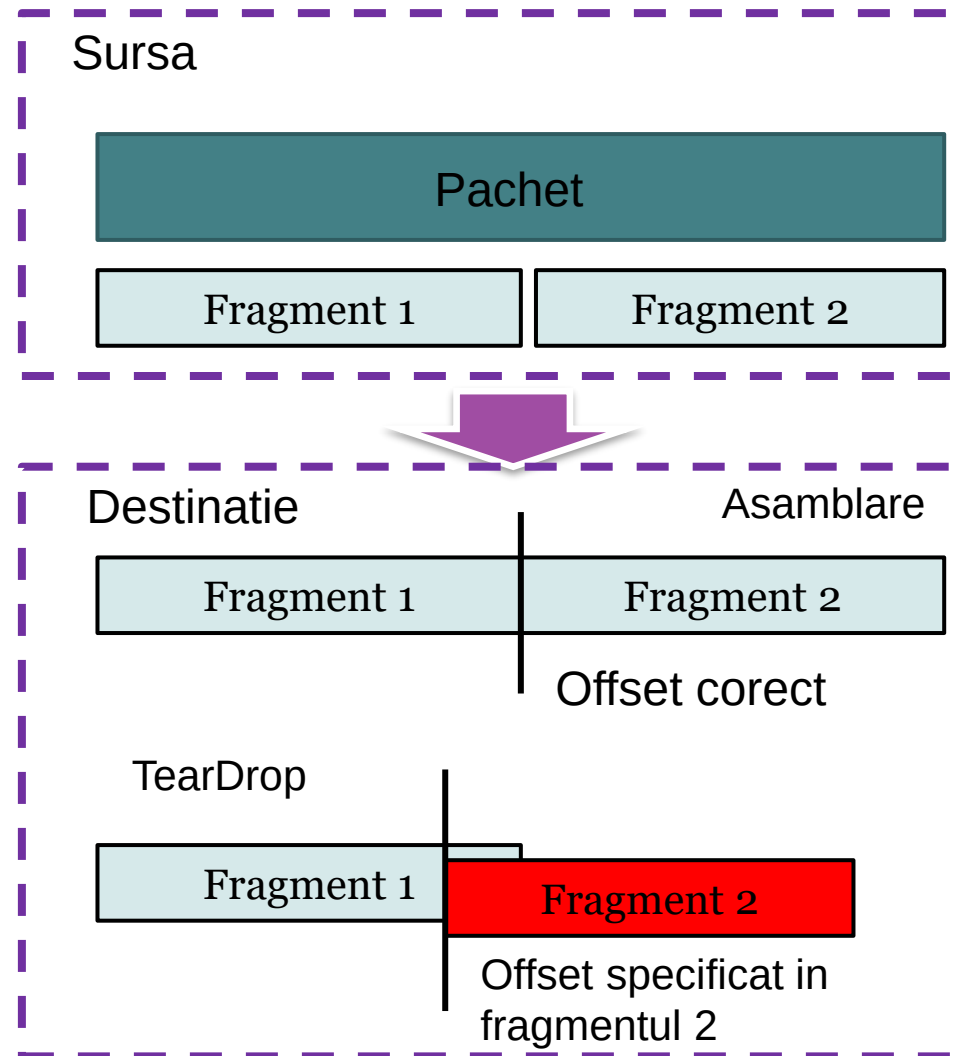
Ping of Death

- ICMP echo cu pachete (nivel IP) fragmentate (nivel data link)
 - Dimensiune maxima a pachetului ICMP: $65535 = 64K$
 - Un pachet = $n \times$ fragmente
 - Pachetul reasamblat din fragmente depaseste “65535 bytes” ($\text{offset} + \text{size} > 65535$)

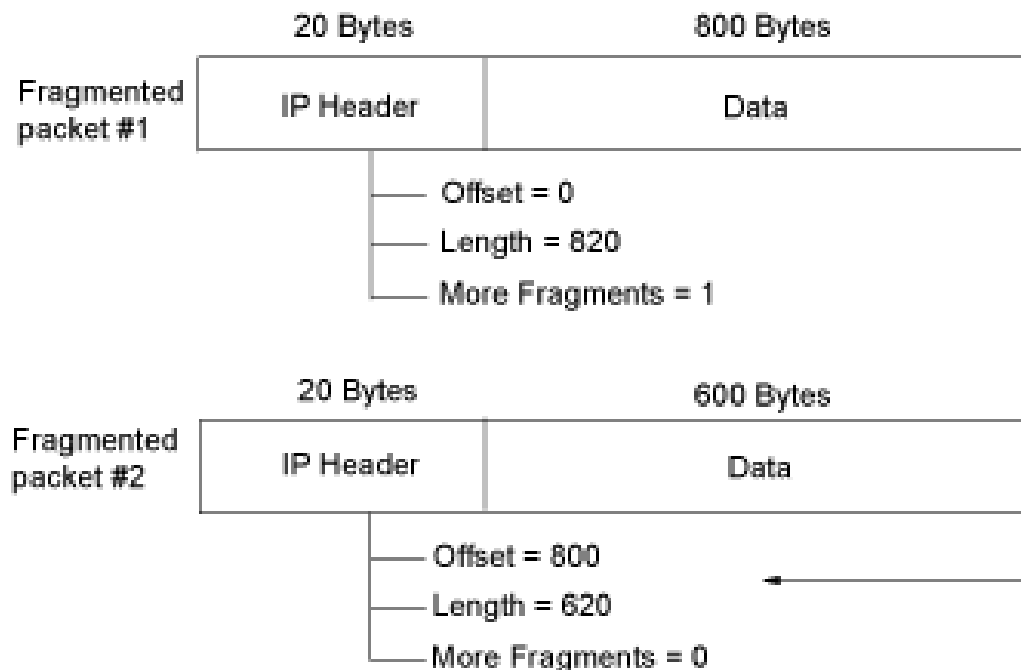


TearDrop

- Se transmite un pachet fragmentat
 - Primul fragment:
 - Offset 0
 - dimensiune N:
 - Al doilea fragment
 - Offset < N (asamblarea ar trebui sa inceapa peste date din primul pachet)
- Sistemul de operare genereaza erori legate de reasamblare



Studiu de caz



The second fragment purports to begin 20 bytes earlier (at 800) than the first fragment ends (at 820). The offset of fragment #2 is not in accord with the packet length of fragment #1. This discrepancy can cause some systems to crash during the reassembly attempt.

ICMP Destination Unreachable

- ICMP cod: **3 Destination Unreachable**

Coduri pentru Destination Unreachable

- 0 = net unreachable (from gateway)
- 1 = host unreachable (from gateway)
- 2 = protocol unreachable (from host)
- 3 = port unreachable (from host)
- 4 = fragmentation needed but do not fragment bit set (from gateway)
- 5 = source route failed (from gateway)

ICMP Redirect

- Mesaj Type 5
- Atacatorul transmite un mesaj “ICMP Redirect” folosind “IP spoofing” (IP-ul sursa al unui router) catre victima
- Mesajul va actualiza tabela de routare schimbând “gateway”-ul catre adresa specificata de atacator

ICMP Time Exceeded

- Mesaj ICMP “Type 11”
- Folosit ca mecanism pentru “traceroute”
- Routerul raspunde printr-un mesaj ICMP la pachete cu “TTL 0”
- Probleme:
 - Folosit pentru maparea retelei
 - Incetineste procesul de routare in caz de atac amplificat (surse multiple)

Linux based net security distro

- **BackTrack**

- Ubuntu
- Combina Auditor Security Linux (based on Knoppix) and WHAX (formerly Whoppix; based on Slax)

- **Network Security Toolkit (NST)**

- Fedora Live CD
- GUI

